Mitigating Exchange Permission Paths to Domain Admins in Active Directory

trimarcsecurity.com/hub-post/mitigating-exchange-permission-paths-to-domain-admins-in-active-directory

February 12, 2019

Updated: Dec 13, 2024

A blog post was published by Dirk-jan Mollema titled "Abusing Exchange: One API call away from Domain Admin " (https://dirkjanm.io/abusing-exchange-one-api-call-away-from-domain-admin/) which highlighted several issues with Exchange permissions and a chained attack which would likely result in a regular user with a mailbox being able to become a Domain Admin in the AD forest. Tools have been released to take advantage of this issue.

Dirk-jan Mollema highlights the key components of the issue in the blog post introduction:

“This blog combines a few known vulnerabilities and known protocol weaknesses into a new attack. There are 3 components which are combined to escalate from any user with a mailbox to Domain Admin access:

** Exchange Servers have (too) high privileges by default*

** NTLM authentication is vulnerable to relay attacks*

** Exchange has a feature which makes it authenticate to an attacker with the computer account of the Exchange server*

...

The main vulnerability here is that Exchange has high privileges in the Active Directory domain. The Exchange Windows Permissions group has WriteDacl access on the Domain object in Active Directory, which enables any member of this group to modify the domain privileges, among which is the privilege to perform DCSync operations. Users or computers with this privilege can perform synchronization operations that are normally used by Domain Controllers to replicate, which allows attackers to synchronize all the hashed passwords of users in the Active Directory.”

Exchange Permissions in Active Directory

At the Microsoft Blue Hat in 2017, Sean Metcalf, Trimarc founder and Active Directory Subject Matter Expert (SME) highlighted issues with Exchange permissions. Some slides from this presentation are shown here as representative samples (the full presentation slide deck is in the Trimarc Presentations section.

*It's important to understand that it **doesn't matter what Active Directory permissions a user has** when using the Exchange management tools. **If the user is authorized, via RBAC,** to perform an action in the Exchange management tools, **the user can perform the action regardless of his or her Active Directory permissions.***

https://technet.microsoft.com/en-us/library/dd638106.aspx

Highly Privileged Exchange Groups

- Exchange Trusted Subsystem (like SYSTEM, only better)
  - *"The Exchange Trusted Subsystem is a highly privileged …Group that has read/write access to every Exchange-related object in the Exchange organization."*
  - Members: Exchange Servers
  - MemberOf: Exchange Windows Permissions
- Exchange Windows Permissions
  - Provides rights to AD objects (users, groups, etc)
  - Members: Exchange Trusted Subsystem
- Organization Management (the DA of the Exchange world)
  - *"Members … have administrative access to the entire Exchange 2013 organization and can perform almost any task against any Exchange 2013 object, with some exceptions.*
    …is a very powerful role and as such, only users or … groups that perform organizational-level administrative tasks that can potentially impact the entire Exchange organization should be members of this role group."
  - Members: 2 to 3 Exchange organization admin accounts (or less)

Exchange RBAC

- Early Exchange versions required AD object delegation for Exchange rights
- Exchange 2010: Exchange Trusted Subsystem
- Exchange has it's own parallel security (RBAC) model
- The Exchange local System account has the power
- Add an account/group to the Exchange Trusted Subsystem group
- Get Local SYSTEM on an Exchange Server…

Exchange Rights

- Exchange has extensive rights throughout Active Directory.
- Modify rights on most objects, including users and groups (even admins).
  - Except AdminSDHolder protected groups/users.
- Access provided through Exchange groups (like Trusted Subsystem)
- In environments where Exchange 2000/2003 was originally installed, those rights persist, potentially providing even more access.
- Migrated to O365?
  Great, all these permissions are still in AD.

Old Exchange Permissions Persist Upgrade after Upgrade…

Exchange 2000 → 2003 → 2007 → 2010 → 2013 → 2016

Microsoft recently published an article (https://portal.msrc.microsoft.com/en-US/security-guidance/advisory/ADV190007) on how to configure EWS throttling which will mitigate the issue(s) that Dirk-jan Mollema raised. The issue with this is that EWS throttling could negatively impact applications like Outlook for Mac and doesn't resolve the escalation path with Exchange permissions configured in AD.

Trimarc has discovered Exchange having elevated permissions in AD in many customer environments while performing Active Directory Security Assessments (ADSAs). Some of the Exchange permissions discovered during Trimarc ADSAs:

· Organization Management has Full Control ("GenericAll") rights at the domain root.

· Exchange Trusted Subsystem has Full Control ("GenericAll") rights at the domain root.

· Exchange Recipient Administrators has Full Control ("GenericAll") rights at the domain root.

· Exchange Windows Permissions has Modify Permissions ("WriteDACL") rights at the domain root.

The last permission on the list is one that, if in place in an AD forest, will likely result in AD compromise. This right should not be required, so removing it from the domain root should have no negative impact on day to day operations. Trimarc recommends creating a new AD group (something like "Privileged Modify Domain Permissions") and grant this right to that group. Add the Exchange Windows Permissions group to this new Privileged Modify Domain Permissions group when this right is required (which should be rare).

PowerShell command to scan and report on the AD domain permissions (requires the AD PowerShell module):

```
$ADDomain = 'DOMAIN.COM'
$DomainRootPermissionsReportDir = 'c:\temp'
$DomainRootPermissionsReportName = 'DomainRootPermissionsReport.csv'

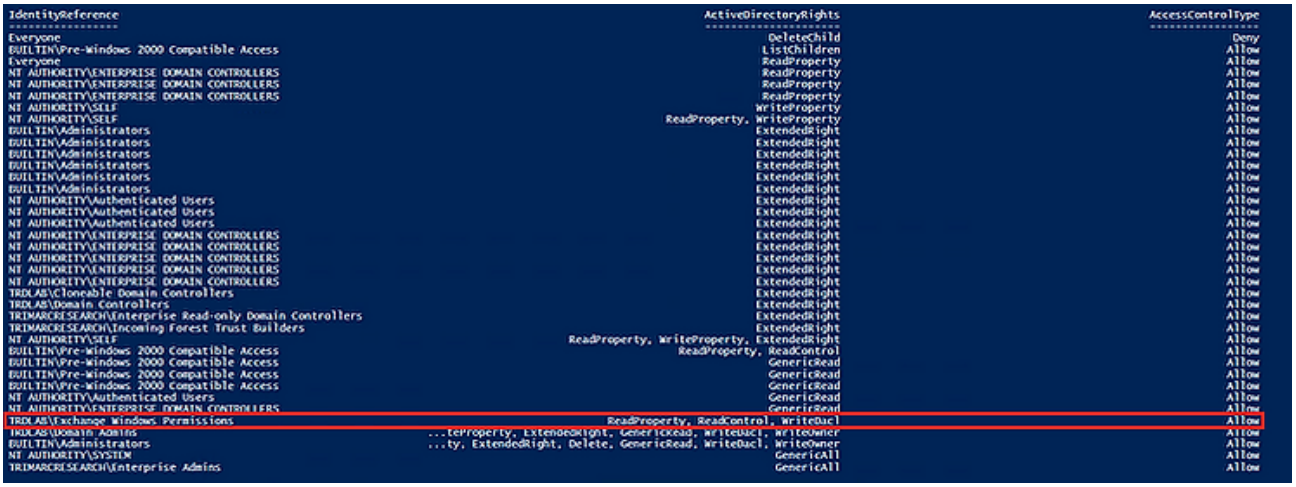
IF (!(Test-Path $DomainRootPermissionsReportDir))
  { new-item -type Directory -path $DomainRootPermissionsReportDir }
$DomainRootPermissionsReportPath = $DomainRootPermissionsReportDir + '\' + $ADDomain + '-' +$DomainRootPermissionsReportName

$DomainTopLevelObjectDN = (Get-ADDomain $ADDomain).DistinguishedName

$DomainRootPermissions = Get-ADObject -Identity $DomainTopLevelObjectDN -Properties * | select -ExpandProperty nTSecurityDescriptor | select -ExpandProperty Access

$DomainRootPermissions | select IdentityReference,ActiveDirectoryRights,AccessControlType,IsInherited,InheritanceType,ObjectType,InheritedObjectType,ObjectFlags,InheritanceFlags,PropagationFlags `
  | export-csv $DomainRootPermissionsReportPath -NoTypeInfo
$DomainRootPermissions | select IdentityReference,ActiveDirectoryRights,AccessControlType,IsInherited | sort ActiveDirectoryRights,IdentityReference

Write-Output " "
Write-Output "-------------------------------+-------------------------------------------------------------------------------------------------------------------------------------------------------------"
Write-Output "|  $ADDomain Domain Permission Report saved to $DomainRootPermissionsReportPath      | "
Write-Output "-------------------------------+-------------------------------------------------------------------------------------------------------------------------------------------------------------"
```



IdentityReference	ActiveDirectoryRights	AccessControlType
Everyone	DeleteChild	Deny
BUILTIN\Pre-Windows 2000 Compatible Access	ListChildren	Allow
Everyone	ReadProperty	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ReadProperty	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ReadProperty	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ReadProperty	Allow
NT AUTHORITY\SELF	WriteProperty	Allow
NT AUTHORITY\SELF	ReadProperty, WriteProperty	Allow
BUILTIN\Administrators	ExtendedRight	Allow
BUILTIN\Administrators	ExtendedRight	Allow
BUILTIN\Administrators	ExtendedRight	Allow
BUILTIN\Administrators	ExtendedRight	Allow
BUILTIN\Administrators	ExtendedRight	Allow
NT AUTHORITY\Authenticated Users	ExtendedRight	Allow
NT AUTHORITY\Authenticated Users	ExtendedRight	Allow
NT AUTHORITY\Authenticated Users	ExtendedRight	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ExtendedRight	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ExtendedRight	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ExtendedRight	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ExtendedRight	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	ExtendedRight	Allow
TRDLAB\Cloneable Domain Controllers	ExtendedRight	Allow
TRDLAB\Domain Controllers	ExtendedRight	Allow
TRIMARCRESEARCH\Enterprise Read-only Domain Controllers	ExtendedRight	Allow
TRIMARCRESEARCH\Incoming Forest Trust Builders	ExtendedRight	Allow
NT AUTHORITY\SELF	ReadProperty, WriteProperty, ExtendedRight	Allow
BUILTIN\Pre-Windows 2000 Compatible Access	ReadProperty, ReadControl	Allow
BUILTIN\Pre-Windows 2000 Compatible Access	GenericRead	Allow
BUILTIN\Pre-Windows 2000 Compatible Access	GenericRead	Allow
BUILTIN\Pre-Windows 2000 Compatible Access	GenericRead	Allow
NT AUTHORITY\Authenticated Users	GenericRead	Allow
NT AUTHORITY\ENTERPRISE DOMAIN CONTROLLERS	GenericRead	Allow
TRDLAB\Exchange Windows Permissions	ReadProperty, ReadControl, WriteDacl	Allow
TRDLAB\Domain Admins	...teProperty, ExtendedRight, GenericRead, WriteDacl, WriteOwner	Allow
BUILTIN\Administrators	...ty, ExtendedRight, Delete, GenericRead, WriteDacl, WriteOwner	Allow
NT AUTHORITY\SYSTEM	GenericAll	Allow
TRIMARCRESEARCH\Enterprise Admins	GenericAll	Allow

Note that this script is provided as a sample and the domain name needs to be changed to correctly gather data.

In more recent versions of Exchange, extensive permissions at the domain level are typically not required. Furthermore, Exchange permissions persist even when the only Exchange server remaining on-premises is for managing Office 365.

Mitigating The Active Directory Security Issues with Microsoft Exchange Permissions

The references noted above highlight issues relating to Exchange permissions and often the mitigation(s) are complicated and difficult to implement.

The goal of this article is to provide a stop gap option that mitigates Exchange permissions that have extensive rights in Active Directory with minimal day-to-day operational impact while organizations can implement a more permanent fix.

For those that are running Exchange on-prem in the Default Shared Permission model and it is not isolated in a dedicated resource forest you need to decide with a fair amount of criticality how you are going to address the permission issue regarding the Exchange Windows Permission group described in https://dirkjanm.io/abusing-exchange-one-api-call-away-from-domain-admin/.

The best method to mitigate the issue with Exchange having elevated AD permissions, and maybe more importantly the way that won't get the "we don't support that" answer from Microsoft, is to switch to Active Directory (AD) split permissions (Exchange) or isolate Exchange in its own resource forest (or both). The split permission model (https://docs.microsoft.com/en-us/exchange/understanding-split-permissions-exchange-2013-help) requires AD management tools for creating security principals in AD (such as users and security groups). Implementing the split permission model is not trivial once Exchange has been deployed, but does effectively limit Exchange rights in AD.

Microsoft notes the following functionality changes when enabling Active Directory split permissions:

· Creation of mailboxes, mail-enabled users, distribution groups, and other security principals is removed from the Exchange management tools.

· Adding and removing distribution group members can't be done from the Exchange management tools.

· All permissions granted to the Exchange Trusted Subsystem and Exchange servers to create security principals are removed.

· Exchange servers and the Exchange management tools can only modify the Exchange attributes of existing security principals in Active Directory.

The key change this stop gap option implements is the removal of the Exchange Trusted Subsystem group from the Exchange Windows Permissions Group, with the work around of temporally restoring the default membership to get around any unforeseen issues.

So here's what that looks like, note that this is just a general overview, this premise will need to be customized based on the nuances of your AD and Exchange environments.

1. Save this link to use as a reference as to what permission changes Exchange made to your Active Directory environment when deployed: https://docs.microsoft.com/en-us/exchange/exchange-2013-deployment-permissions-reference-exchange-2013-help

2. Create a custom RBAC group with the same roles as the Organization Management group removing the requirement for administrators to have permanent membership in Organization Management. Call this group something like "<DOMAIN/FOREST_NAME> Exchange Organization Management". This can be easily be done using the RBAC cmdlets in Exchange Management Shell. "*By default, the Organization Management group can modify group membership of the Exchange Trusted Subsystem, Exchange Windows Permissions, and other Exchange privileged groups in Active Directory".* This article from Microsoft walks you through the process of copying an Exchange role group: https://docs.microsoft.com/en-us/exchange/permissions/role-groups?view=exchserver-2019

3. Delegate more appropriate AD rights to the group created in step 2 ("<DOMAIN/FOREST_NAME> Exchange Organization Management") at the appropriate OU level based on your AD OU design. Reference the link provided in Step 1.

4. Remove the Exchange Trusted Subsystem group from the Exchange Windows Permissions group and any other groups that are members of Exchange Windows Permissions group. This isolates Exchange from having AD permissions. Ensure that only Exchange Servers are members in the Exchange Trusted Subsystem group.

5. Use the reference in step 1 to apply the permissions delegated to the Exchange Windows Permission group by default to the Exchange Trusted Subsystem group but this time at the appropriate OU level versus at the domain root.

6. Remove any membership from the Organization Management group.

7. Ensure that monitoring and alerting is configured for membership changes of the following groups:

· Exchange Windows Permission

· Exchange Trusted Subsystem

· Organization Management

8. When the removed permissions are required, temporarily add the Exchange Trusted Subsystem group to the Exchange Windows Permissions group. Ensure that this group is removed when the required tasks are completed.

Ensure that you use groups instead of adding individual user or computer accounts directly in these permission groups as this should reduce the need to reboot computers and log off and then back on again. Note that this configuration will break things and add some additional burden to the administration of Exchange but hopefully have little to no impact in the day to day use of Exchange by end users.

For example if you attempt to install a new Exchange Server in the environment you should get an error, but to get around this you can add the admin account that is installing the new Exchange server temporarily to the default Organization Management Group and temporarily add Exchange Trusted Subsystem group to the Exchange Windows Permission Group, this is the work around for anything this new configuration might break which should mostly be related to object creation in the domain partition in AD.

Also, if using the AD split permission model as an example as to what other things this premise might break, using the Add-ADpermission cmdlet to add permissions to a mailbox will probably break as well but should still work for receive connectors because mailbox objects are stored in the domain partition and receive connectors are stored in the configuration partition.

Also should you need to engage Microsoft support its easy enough to put yourself back into the “supported” configuration by simply giving the Exchange Trusted Subsystem group temporary membership to the Exchange Windows Permission Group.

This premise is not been fully tested out to see what all the unintended consequences in every environment might be but can be switched back to the supported configuration temporarily as a work around when something breaks.

It has to be emphasized again that this is only a stop gap meant to give organizations a possible short term option that can be implemented rather quickly while the correct fix or path is put in place for that Organization.

UPDATE

On February 12, 2019, Microsoft released patches that modifies Exchange Web Services Push Notifications to protect against the issue identified in Dirk-jan Mollema's blog post and Microsoft also reduces the rights that Exchange has to Active Directory. This requires that the new version of setup.exe /PrepareAD is run.

An architectural change to Exchange Web Services (EWS) Push Notifications authentication is included in all packages released today. KB4490060 outlines the details of the changes made. Customers who rely upon Push Notifications, should understand the important changes made. We have evaluated the changes to push notifications against many commonly used EWS clients, e.g. Outlook Mac, Skype for Business Client, native iOS mail clients and observed no loss of functionality due to these changes. EWS Pull and Streaming Notifications functionality are unchanged by today's updates.

The update to EWS Push Notifications is considered a critical security update and customers should deploy the update as soon as they understand and accept any potential impact. The change in Push Notification authentication is a permanent change to the product and necessary to protect the security of an Exchange Server.

After applying either the cumulative update or update rollup to a server, customers are advised to force a reset of the Exchange servers' credentials stored in Active Directory. This can be accomplished using the Reset-ComputerMachinePassword cmdlet in PowerShell 5.1 or later. If PowerShell is not an option, netdom or Active Directory Users and Computers can also be used. Microsoft knows of no instances where machine accounts have been compromised. Updating a machine account password is considered a best practice to ensure the security of the server is not compromised. In addition, customers are encouraged to evaluate if their user password expiration policies are appropriate for Exchange enabled accounts.

Decreasing Exchange Rights in the Active Directory

The Exchange team has determined a change in the Active Directory rights granted to Exchange Servers using the default Shared Permissions Model is in order. Changes in the latest cumulative updates, described in KB4490059, reduce the scope of objects where Exchange is able to write security descriptors in the directory.

In order to apply these changes, a directory admin will need to run the cumulative update setup program with the /PrepareAD parameter. When multiple Exchange versions co-exist in a single Active Directory forest, the cumulative update matching the latest version of Exchange deployed should be used to run /PrepareAD. Setup will automatically run /PrepareDomain in the domain where /PrepareAD is executed. Environments with multiple domains in the forest will need to run the cumulative update setup program using the /PrepareDomain parameter in all domains in the forest. These steps will update the rights granted to Exchange Servers in the Active Directory to meet the new permissions scope. More information on /PrepareAD and /PrepareDomain is available at this link.

Customers running only Exchange Server 2010 will need to follow the instructions in KB4490059 to update their environments. The update rollup package released for 2010 will not apply the directory changes.

The directory updates described in KB4490059 are fully compatible with all versions of Exchange Server regardless of cumulative update or update rollup version deployed. There is no loss of product functionality associated with these updates.

The rights granted to Exchange in Active Directory using the Active Directory Split Permissions Model are unchanged by the updates released today.

Shared Permissions vs. Split Permissions Model

Early advisories released by Microsoft related to this vulnerability indicated that Active Directory Split Permissions Model was a possible mitigation to Domain Admin elevation. It is true Split Permissions affords additional directory protection over the Shared Permissions Model. However, Microsoft fully supports both modes of directory operation and recognizes that there are relative strengths and weaknesses inherent to both models. Before implementing a change of this type, customers should fully evaluate the impact to line of business processes, security and operational needs. The changes released today improve the security profile of the Shared Permissions Model, while retaining the administrative flexibility

Conclusion

When Exchange was originally installed, it configures and grants itself extensive Active Directory permissions. These permissions provide necessary access that Exchange may never need. The issue is that these permissions are overly permissive, especially when early versions of Exchange were deployed (since Exchange 2000/2003 added extensive permissions compared to current versions).

The Microsoft Exchange split permission model or deploying an Exchange resource forest are the best methods to mitigate attacks on AD through Exchange permissions, though

these are not easy to deploy or configure (or retrofit). Trimarc has identified a method that switches the configuration from a permanent Exchange permissions model to one where the required permissions can be provided on a "when needed" (or just in time) basis.

Trimarc provides leading expertise in security solutions including security reviews, strategy, architecture, and implementation. Our methodology leverages our internal research and custom tooling which better discovers multiple security issues attackers could exploit to compromise the environment. Trimarc security services fit between traditional compliance/audit reviews and standard penetration testing/red teaming engagements, providing deep understanding of Microsoft technologies, typical security issues and misconfigurations, and provide recommendations based on our own best practices custom-tailored to balance operational and security challenges.